

Ethical Hacker



Networking
Academy



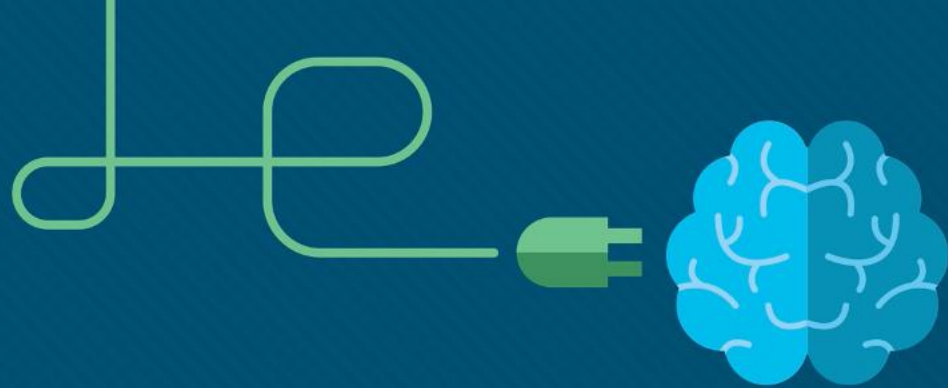
Programa
CiberEducação
Cisco-Brasil



Módulo 4: Ataques de engenharia social

Instrutor: 1º Ten Efísio





Módulo 4: Ataques de engenharia social

Hacker Ético



Objetivos do Módulo

Título do módulo: Ataques de engenharia social

Objetivo do módulo: Explique como os ataques de engenharia social são bem-sucedidos.

Título do tópico	Objetivo do Tópico
Pretexting e Impersonação	Explique como o pretexting é usado em ataques de engenharia social.
Ataques de engenharia social	Explique diferentes tipos de ataques de engenharia social.
Ataques físicos	Explique diferentes tipos de ataques físicos.
Ferramentas de engenharia social	Explique como as ferramentas de ataque de engenharia social facilitam os ataques.
Métodos de Influência	Explique como os ataques de engenharia social envolvem a participação do usuário.

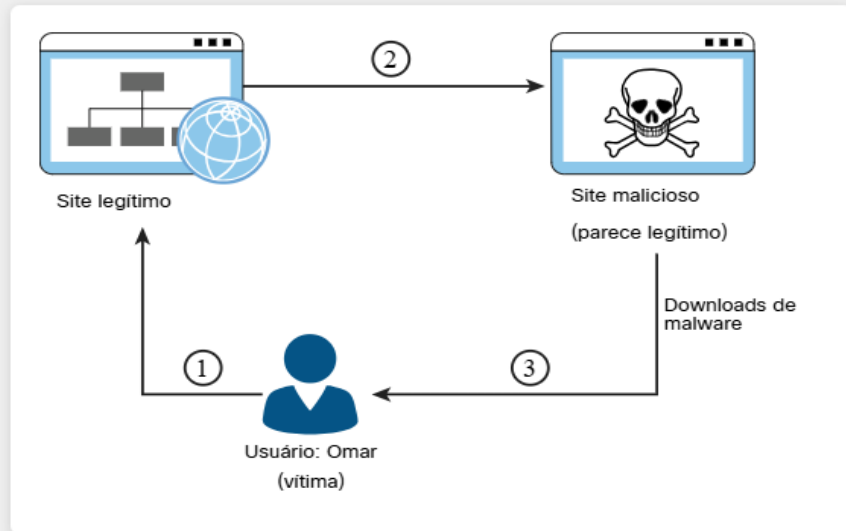
4.1 Pretexting e Impersonação

Visão geral

- **Ataques** de engenharia social: **Ataques contra o elo mais fraco, que é o elemento humano como phishing, vishing, pharming, spear phishing, whaling e outros.**
- Há outras técnicas de engenharia social, como elicitación, interrogatório e impostura.
 - A elicitación é o ato de obter conhecimento ou informação das pessoas.
 - O interrogatório é como um agressor interage com uma vítima para o sucesso de uma campanha de engenharia social. O interrogador pode então usar qualquer informação que o alvo revelou para continuar a reunir informações adicionais ou obter informações de outra vítima.
 - Com pretexting, ou personificação, o agressor se apresenta como outra pessoa para obter acesso a informações. Os engenheiros sociais podem usar a personificação para representar indivíduos em certos trabalhos e funções, mesmo que não tenham experiência nesses trabalhos ou funções. **Pharming** é um tipo de ataque de impostura no qual um ator de ameaça redireciona uma vítima de um site ou recurso válido para um malicioso que poderia ser feito para aparecer como o site válido para o usuário. A partir daí, é feita uma tentativa de extrair informações confidenciais do usuário ou instalar malware no sistema da vítima.

Pretexto para uma abordagem e imitação

Figura 4-1 - Exemplo de pharming



As etapas a seguir são ilustradas na Figura 4-1:

Etapa 1. O usuário (Omar) visita um site legítimo e clica em um link legítimo.

Etapa 2. O sistema de Omar está comprometido, o arquivo do host é modificado, e Omar é redirecionado para um site malicioso que parece ser legítimo. (Isso também pode ser feito comprometendo um servidor DNS ou falsificando uma resposta DNS.)

Etapa 3. Malware é baixado e instalado no sistema de Omar.

Um ataque semelhante ao pharming é chamado *de malvertising*. Malvertising envolve incorporar anúncios maliciosos em sites confiáveis. Os usuários que clicam nesses anúncios são inadvertidamente redirecionados para sites que hospedam malware.

Pretexto para uma abordagem e imitação

Visão geral

Facebook

Correio electrónico: Contraseña: Entrar

☐ No entrar sesión ¿Has olvidado tu contraseña?

Facebook te ayuda a comunicarte y compartir con las personas que forman parte de tu vida.



Regístrate
Es gratis y lo será siempre.

Nombre: Apellidos:

Correo electrónico:

Vuelve a introducir el correo electrónico:

Contraseña nueva:

Fecha de nacimiento: Día: Mes: Año: ¿Por qué tengo que dar mi fecha de nacimiento?

☐ Mujer ☐ Hombre

Al hacer clic en Terminado, aceptas las Condiciones y que has leído la Política de uso de datos, incluido el uso de cookies.

Terminado

Facebook

Correo electrónico: Contraseña: Entrar

☐ No entrar sesión ¿Has olvidado tu contraseña?

Facebook te ayuda a comunicarte y compartir con las personas que forman parte de tu vida.



Regístrate
Es gratis (y lo seguirá siendo).

Nombre:

Apellidos:

Tu correo electrónico:

Vuelve a escribir tu correo:

Contraseña:

Sexo: Selecciona el sexo:

Fecha de nacimiento: Día: Mes: Año: ¿Por qué tengo que dar esta información?

Terminado

Dúvidas ?

4.2 Ataques de Engenharia Social

Visão geral

- A engenharia social pode ser feita por meio de **e-mail ou desvio de páginas da Web** e levando o usuário a clicar em algo que permita ao agressor obter informações.
- A engenharia social também pode ser feita pessoalmente por um membro interno ou por uma entidade externa ou pelo telefone.
- Um exemplo principal são os atacantes que aproveitam o comportamento normal do usuário.

Phishing por email

- Com ***phishing***, um atacante apresenta a um usuário um link ou um anexo que parece um recurso válido e confiável. Quando o usuário clica nele, o usuário é solicitado a revelar informações confidenciais, como seu nome de usuário e senha.

Phishing por email

- Com **phishing**, um atacante apresenta a um usuário um link ou um anexo que parece um recurso válido e confiável. Quando o usuário clica nele, o usuário é solicitado a revelar informações confidenciais, como seu nome de usuário e senha.

Assunto: CONFIRMAÇÃO DE PAGAMENTO

Corpo da Mensagem:

Prezado senhor,

Identificamos que ocorreram atrasos de nosso departamento financeiro no pagamento integral aos nossos fornecedores.

Isso tem causado uma redução indevida em nossos estoques e em nosso departamento de produção, visto que os fornecedores não entregam os materiais no prazo. O objetivo deste email é confirmar se o pagamento das remessas anexas recebidas foi ou não efetuado.

Por favor, confirme o recebimento e nos informe.

Anexo: SD_085_085_pdf.xz / SD_085_085_pdf.exe

Checksum MD5 do anexo: 0x8CB6D923E48B51A1CB3B080A0D43589D

Phishing por email

- Com ***phishing***, um atacante apresenta a um usuário um link ou um anexo que parece um recurso válido e confiável. Quando o usuário clica nele, o usuário é solicitado a revelar informações confidenciais, como seu nome de usuário e senha.
- ***Spear phishing*** é uma tentativa de phishing que é construída de uma forma muito específica e diretamente destinada a grupos específicos de indivíduos ou empresas.

Phishing por email

- Com ***phishing***, um atacante apresenta a um usuário um link ou um anexo que parece um recurso válido e confiável. Quando o usuário clica nele, o usuário é solicitado a revelar informações confidenciais, como seu nome de usuário e senha.
- ***Spear phishing*** é uma tentativa de phishing que é construída de uma forma muito específica e diretamente destinada a grupos específicos de indivíduos ou empresas.

De: Chris Cleveland

Para: Omar Santos

Assunto: Por favor, revise o capítulo 3 para mim e envie o feedback até as 14h

Corpo da Mensagem: Caro Omar,

Por favor, revise o documento em anexo.

Atenciosamente, Chris

Anexo: chapter.zip

MD5 Checksum do anexo: 0x61D60EA55AC14444291AA1F911F3B1BE



Phishing por email

- Com **phishing**, um atacante apresenta a um usuário um link ou um anexo que parece um recurso válido e confiável. Quando o usuário clica nele, o usuário é solicitado a revelar informações confidenciais, como seu nome de usuário e senha.
- **Spear phishing** é uma tentativa de phishing que é construída de uma forma muito específica e diretamente destinada a grupos específicos de indivíduos ou empresas.
- **O whaling**, que é semelhante ao phishing e spear phishing, é um ataque direcionado a executivos de negócios de alto perfil e indivíduos-chave em uma empresa.
- **Serviço de Mensagens Curtas (SMS) phising**: as campanhas de phishing geralmente usam mensagens de texto para enviar links mal-intencionados ou malware para dispositivos móveis.

Vishing

- Vishing (que é abreviação de phishing de voz) é um ataque de engenharia social realizado em uma conversa telefônica. O agressor convence o usuário a revelar informações pessoais e financeiras privadas ou informações sobre outra pessoa ou empresa.
- O objetivo do vishing é normalmente roubar números de cartão de crédito, números de Previdência Social e outras informações que podem ser usadas em esquemas de roubo de identidade. Os agressores podem fingir ser e falsificar a ID do chamador para se esconderem ao realizar ataques vishing.
- **https://www.youtube.com/watch?v=Vc6DxiKh_4w**

Chave USB deixada

- Esse tipo de ataque envolve apenas deixar os pendrives sem supervisão ou colocá-los em locais estratégicos. Muitas vezes, os usuários pensam que os dispositivos são perdidos e os inserem em seus sistemas para descobrir a quem devolver os dispositivos; antes de saberem, eles estão baixando e instalando o malware.
- Uma pesquisa de Elie Bursztein, da equipe de pesquisa anti-abuso do Google, mostra que a maioria dos usuários conectará unidades USB ao seu sistema sem hesitação. Como parte de sua pesquisa, ele deixou cerca de 300 unidades USB no campus da Universidade de Illinois Urbana-Champaign e mediu quem conectava as unidades. Os resultados mostraram que 98% das unidades USB foram recolhidas e, para 45% das unidades, alguém não só conectou a unidade como clicou em arquivos.
- Outra técnica de engenharia social envolve deixar cair um chaveiro contendo um pendrive que também pode incluir fotos de crianças ou animais de estimação e uma chave ou duas reais. Esses tipos de toques pessoais podem levar a vítima a tentar identificar o proprietário a fim de retornar o chaveiro.

Ataques de Watering Hole

- Um **ataque de Watering Hole** é um ataque direcionado que ocorre quando um agressor perfila sites que a vítima pretendida acessa. O agressor então verifica esses sites para possíveis vulnerabilidades.
- Se o agressor localizar um site que pode ser comprometido, o site é então injetado com código que é projetado para redirecionar o usuário quando o usuário retorna para esse site.
- O usuário é então redirecionado para um site com algum tipo de código de exploração.
- Os ataques de watering hole são frequentemente projetados para perfilar usuários de organizações específicas.

4.2.8 Prática - Ataques de engenharia social

Após nossas entrevistas iniciais com funcionários e outras partes interessadas em Pixel Paradise, é importante que classifiquemos adequadamente os tipos de ataques de engenharia social que eles experimentaram. Isso nos ajuda a criar recomendações de mitigação direcionadas que se adaptem ao cliente específico. Para praticar essa habilidade, corresponda a descrição do ataque de engenharia social ao tipo de ataque.

Categorias:

Ataque watering hole

A

Whaling

B

Opções:

Vários funcionários da Protego receberam mensagens de texto que instruíram-nos a clicar em um link para confirmar uma conta e reivindicar uma recompensa em bitcoin. O site precisava de registro com informações pessoais e relacionadas ao trabalho.

O vice-presidente de finanças e diretor de contabilidade da Protego receberam e-mails que continham links para uma pesquisa online sobre gestão financeira. Um deles clicou no link e seu aplicativo anti-malware bloqueou um download de arquivo malicioso.

Dúvidas ?

4.3 Ataques físicos

Visão geral

- Como testador de penetração ou red teamer, talvez seja solicitado que você simule o que um agente de ameaça ou criminoso real pode fazer para comprometer a segurança física de uma organização a fim de obter acesso à infraestrutura, edifícios, sistemas e funcionários.

Acompanhamento não autorizado

- Com *carona*, uma pessoa não autorizada acompanha uma pessoa autorizada para obter entrada em uma área restrita – normalmente com o consentimento da pessoa.
- ***Acompanhamento não autorizado*** é essencialmente o mesmo, mas com uma diferença: geralmente ocorre sem o consentimento da pessoa autorizada.
- Tanto o carona quanto o acompanhamento não autorizado podem ser derrotados através do uso de vestíbulos de controle de acesso.
- Um vestíbulo de controle de acesso é um pequeno espaço que comporta geralmente apenas uma pessoa. Ele tem dois conjuntos de portas estreitamente espaçadas; O primeiro conjunto deve ser fechado antes do outro ser aberto, criando uma espécie de sala de espera onde as pessoas são identificadas (e não podem escapar).
- A autenticação multifator é frequentemente usada em conjunto com um vestíbulo de controle de acesso.

Mergulho na lixeira

- **Com Dumpster diving, uma pessoa procura informações privadas em contêineres de lixo e reciclagem.**
- Para proteger documentos confidenciais, uma organização deve armazená-los em um local seguro o maior tempo possível.
- Quando não precisa mais dos documentos, a organização deve triturá-los.
- Mergulhadores de lixeiras podem encontrar informações em papel e em discos rígidos ou mídia removível.

Espionagem Visual

- Com **a espionagem visual**, alguém obtém informações como PII, senhas e outros dados confidenciais olhando por cima do ombro da vítima.
- Uma maneira de fazer isso é se aproximar de uma pessoa e olhar por cima do ombro para ver o que a pessoa está digitando em um laptop, telefone ou tablet.
- Também é possível realizar esse tipo de ataque de longe usando binoculares ou mesmo um telescópio. Estes ataques tendem a ser especialmente bem-sucedidos em lugares lotados.
- Além disso, a espionagem visual pode ser realizada com pequenas câmeras e microfones ocultos.
- A conscientização e treinamento dos usuários são fundamentais para a prevenção.

Clonagem de crachá

- Os agressores podem executar ataques de clonagem de crachá diferentes.
- Por exemplo, um agressor pode clonar um crachá/cartão usado para acessar um prédio.
- Software e hardware especializados podem ser usados para realizar estes ataques de clonagem.
- Os agressores também podem usar técnicas de engenharia social para representar funcionários ou qualquer outro usuário autorizado a entrar em um prédio apenas criando seu próprio crachá e tentando enganar outros usuários para deixá-los entrar em um prédio.
- Isso poderia até ser feito sem um clone completo das capacidades de radiofrequência (RF) de um crachá.

Clonagem de crachá



Clonagem de crachá

- <https://www.youtube.com/shorts/X6m2237yPXk>
- <https://www.youtube.com/watch?v=2bb45r2Cbh4>



Dúvidas ?

4.5 Métodos de Influência

Visão geral

São técnicas de motivação da engenharia social/métodos de influência:

- **Autoridade** - Um engenheiro social demonstra confiança e, talvez, autoridade – seja legal, organizacional ou social.
- **Escassez e Urgência** - É possível usar a escassez para criar um sentimento de urgência em um contexto de tomada de decisão. Uma linguagem específica pode ser usada para aumentar a urgência e manipular a vítima. Os vendedores geralmente usam a escassez para manipular clientes.
- **Prova Social** é um fenômeno psicológico no qual um indivíduo não consegue determinar o modo de comportamento adequado. Engenheiros sociais podem aproveitar as provas sociais quando um indivíduo entra em uma situação desconhecida com a qual não sabe como lidar.
- **Semelhança** - Indivíduos podem ser influenciados por coisas ou pessoas que eles gostam. Os engenheiros sociais se esforçam para que os outros gostem da maneira como se comportam, parecem e conversam. Engenheiros sociais aproveitam-se das vulnerabilidades humanas para manipular suas vítimas.
- **Medo** - É possível manipular uma pessoa com medo para que ela aja prontamente. O medo é uma emoção desagradável baseada na crença de que algo ruim ou perigoso pode acontecer.

Ataques de engenharia social

Prática

4.5.2 Prática - Métodos de influência

Você foi convidado para participar de uma campanha de engenharia social no teste Pixel Paradise. Você deve redigir mensagens de e-mail e scripts de chamada para serem usados na campanha. Isso envolve o desenvolvimento de estratégias para influenciar os funcionários a visitar um site infectado com scripts hook.js BeEF. Corresponda cada um dos métodos de influência ao modo como você o utilizaria.

Categorias:

escassez

A

medo

B

Opções:

Você age com confiança e invoca poder legal, organizacional ou social para convencer as vítimas a cumprir.

Você força as vítimas a agir rapidamente para evitar ou retificar uma situação perigosa ou desagradável.

4.4 Ferramentas de Engenharia Social

Ferramentas de Engenharia Social

Visão geral

```
ssh omar@192.168.88.225

=====

[---] The Social-Engineer Toolkit (SET) [---]
[---] Created by: David Kennedy (ReL1K) [---]
[---] Version: 8.0.3 [---]
[---] Codename: 'Maverick' [---]
[---] Follow us on Twitter: @TrustedSec [---]
[---] Follow me on Twitter: @HackingDave [---]
[---] Homepage: https://www.trustedsec.com [---]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

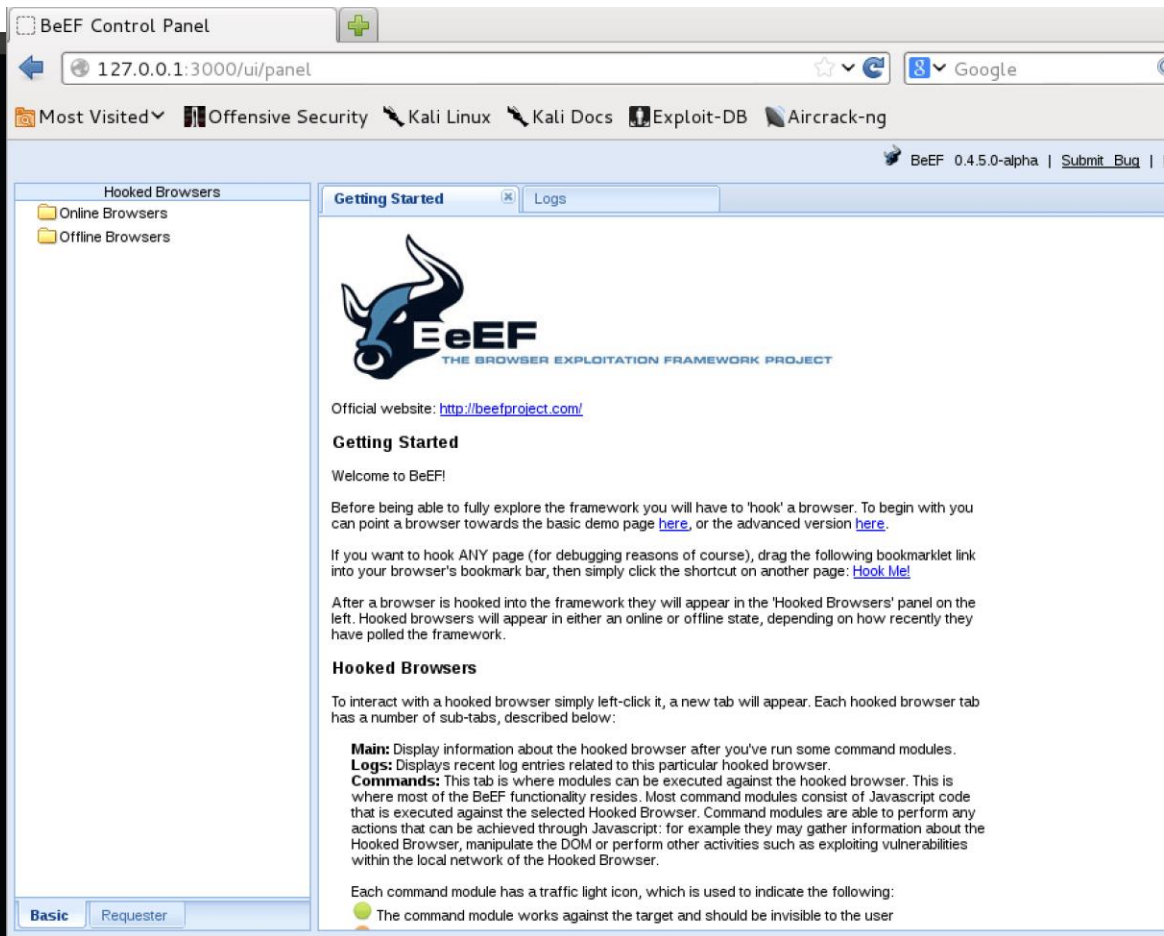
It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

Select from the menu:

1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track)
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit

set>
```



Lab - Explore o Social Engineer Toolkit (SET)

Neste laboratório, você irá cumprir os seguintes objetivos:

- Parte 1: Iniciando SET e explorando o kit de ferramentas
- Parte 2: Clonar um site para obter credenciais de usuário
- Parte 3: Capturando e exibindo credenciais de usuário

Lab - Usando o Browser Exploitation Framework (BeEF)

Neste laboratório, você irá cumprir os seguintes objetivos:

- Carregar o ambiente GUI do BeEF
- Conectar o navegador local para simular um ataque do lado do cliente
- Investigar capacidades de exploração da BeEF

Dúvidas ?

Ferramentas de falsificação de chamadas

- É possível alterar facilmente as informações de ID do chamador exibidas no telefone.

Veja a seguir alguns exemplos de ferramentas de falsificação de chamadas:

- **SpoofApp:** Esse é um aplicativo do Apple iOS e Android que pode ser usado para falsificar facilmente um número de telefone.
- **SpoofCard:** Esse é um aplicativo da Apple iOS e Android que pode falsificar um número e alterar sua voz, gravar chamadas, gerar ruídos de fundo diferentes e enviar chamadas diretamente para o correio de voz.
- **Asterisk:** Asterisk é uma ferramenta de gerenciamento de voz legítima sobre IP (VoIP) que também pode ser usada para falsificar o identificador de chamadas.

4.6 Resumo

Resumo

- Este módulo explicou os conceitos de pretexto para uma abordagem e imitação, ataques de engenharia social, ataques físicos, ferramentas de engenharia social e métodos de influência.
- Por que os agressores fazem ataques de engenharia social?
- O que os agressores ganham com as vítimas de ataques de engenharia social?
- Quais são exemplos de ferramentas de engenharia social?
- Quais são os métodos de influência e como são usados?



Networking
Academy



Programa
CiberEducação
Cisco-Brasil



Obrigado pela Atenção